IT維運 × 資訊安全管理

ISMS與帳號權限管理整合實例

Ragic
AD / NAS / 郵件

將分散的帳號資料，接到人員異動、權限複審與維護紀錄。

陳家榮｜IT維運與系統管理

誰持有帳號

帳號分散在不同平台，人員異動時需要逐一確認。

權限是否仍需要

帳號仍在使用，不代表原群組與資料夾授權都應保留。

處理結果如何查

核准內容、來源設定與清冊紀錄，需要能夠相互對照。

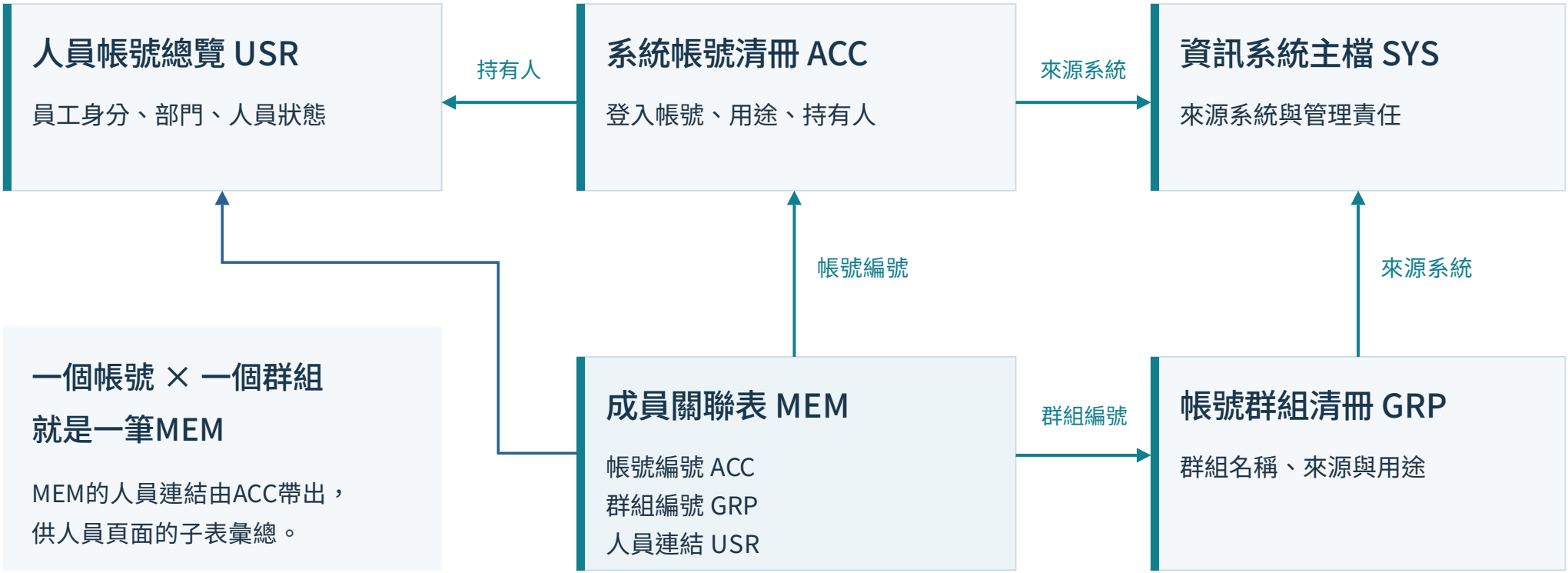
我的做法

進修ISO/IEC 27001後，我以Ragic建立十張關聯表單，整理人員、帳號、群組及NAS授權，並將申請、核對、覆核與紀錄保存接入ISMS文件草案。

作品說明：依既有系統與修訂草案整理。示例資料皆為虛構；新增制度與頻率仍待組織核准。

02 把人員、帳號與群組接起來

十張表單中的身分與成員關係。使用穩定編號配對，避免只靠姓名或相同登入名稱判斷。



箭頭代表連結欄位引用主檔；參照子表可呈現關聯資料，實際更新仍依欄位設定。[2]

授權延伸　PERM引用資料夾FOLDER與ACC／GRP；SYS、HW、VEN、VCT記錄系統、設備及維護關係。

03 把管理要求落到欄位與紀錄

以ISO/IEC 27001管理觀念整理設計對照，讓每項管理動作都有可查詢的資料與處理依據。[1]

管理重點	本案的設計方式	對應表單	參考對應（2022 版）	保留的證據
身分與責任	區分個人、共用、服務及儀器帳號；指定責任人。	USR／ACC	A.5.16 身分識別管理	帳號用途、歸屬與核准依據
權限生命週期	依到職、調職、離職需求，核准新增、調整及回收。	F-05-01 USR／ACC	A.5.18 存取權限 A.6.5 任用終止或變更後責任	生效時間、來源執行與覆核
群組與資料夾授權	以成員關聯與授權規則追溯帳號，保留來源系統。	GRP／MEM FOLDER／PERM	A.5.15 存取控制 A.8.3 資訊存取限制	來源快照、授權內容與差異
定期權限複審	清冊更新後，由權責人判斷權限是否仍有必要；特權帳號另列複審。	F-05-02 F-05-03	A.5.18 存取權限 A.8.2 特權存取權	續用／調整／移除判斷與結案
紀錄與持續改善	核對匯入、關聯及公式，記錄異常、處理與追蹤。	WI-05-01 F-05-03	本文 7.5 文件化資訊 本文 10 改善	批次核對、抽查結果與改善紀錄

F-05-01使用者權限申請異動單、F-05-02權限定期複審表、F-05-03清冊更新與差異追蹤表、WI-05-01帳號與權限清冊維護作業指引，均為本案配套草案。參考對應採ISO/IEC 27001:2022附錄A（名稱依本案SoA草案）及本文條號，僅作設計對照，不代表已通過驗證。

04 以調職為例 串起申請到覆核

示例：示範員工由A部門調至B部門。確認新職務需求，並回收不再需要的原群組與資料夾權限。

01
人資／主管
提出異動
員工、部門與
預定生效時間

→

02
權責主管
核准需求
保留、新增、回收
及交接例外；
例外需設到期日

→

03
IT執行人
來源系統變更
實際調整AD／NAS
或郵件權限

→

04
IT執行人
更新Ragic
匯入並核對
關聯與公式

→

05
指定覆核人
確認與留存
對照核准、來源
與清冊結果；
覆核人不兼執行人

重點：Ragic保存查詢與盤點紀錄；來源系統的實際權限，仍須由IT執行並查證。

資料物件	調整前	調整後（示意）	判斷意義
人員 USR	在職／A部門	在職／B部門	調職仍是在職人員。
登入帳號 ACC	啟用	啟用	仍需要使用的帳號可繼續保留。
群組成員 MEM	原群組有效	原群組移除／新群組有效	群組調整以成員關聯記錄。
資料夾授權 PERM	原部門資料夾個人授權有效	移除，或經核准暫留並設到期日	個人授權不隨群組調整消失，需逐筆確認。

人員狀態、帳號狀態與成員狀態各有用途；移除一項群組關係，不等同停用整個帳號。

05 用紀錄編號串起申請與調整結果

欄位重繪示例。人員、帳號、群組及案件均為虛構；本頁展示配套表單與清冊的對照方式。

使用者權限申請異動單 F-05-01

申請編號	REQ-DEMO-01
異動人員／USR	示範員工甲／USR-DEMO-01
申請類別	調職：A部門至B部門
涉及系統／帳號	SYS-DEMO-NAS／ACC-DEMO-01
權限明細	移除GRP-DEMO-A；加入GRP-DEMO-B
核准／執行／覆核	示範主管乙／示範IT丙／示範覆核丁

成員關聯表 調整前後示意

成員關聯編號	MEM-DEMO-01	MEM-DEMO-02
帳號編號	ACC-DEMO-01	ACC-DEMO-01
人員連結	USR-DEMO-01	USR-DEMO-01
群組編號	GRP-DEMO-A	GRP-DEMO-B
來源系統	SYS-DEMO-NAS	SYS-DEMO-NAS
成員／一致性	已移除／一致	有效／一致

批次紀錄 F-05-03　BATCH-DEMO-01 對照 REQ-DEMO-01 與 MEM-DEMO-01、MEM-DEMO-02

申請與覆核證據可先留在受控表單，由更新批次記錄對應的清冊編號。

同一帳號加入新群組會形成另一筆MEM；原關聯改為已移除並保留紀錄，方便後續查詢。

06 目前完成的設計與後續方向

以維運需求出發，逐步補足身分關聯、作業流程與查核依據；首次全面盤點已完成。

已完成的系統與文件設計

- 十張表單的人員、帳號與授權關聯。
- AD／NAS資料匯出、匯入與核對流程。
- 申請、複審及差異追蹤等ISMS草案。
- 完成AD與三台NAS的首次全面盤點，異常已回平台修正。
- 差異比對工具：自動產生差異清單與分類匯入檔。

後續規劃

- 納入Microsoft 365等雲端帳號。
- 串接人資提出的人員異動申請。
- 由人員資料產生待調整權限報表。
- 仍使用本機帳號的NAS加入網域，收斂身分來源。

正式導入前的確認

由組織核定角色、時限與複審頻率，再以實際案件試行；同時確認Ragic權限、備份及還原方式，保留測試與核准紀錄。

設計心得

把誰核准、IT做了什麼，以及如何確認結果寫清楚，
讓清冊成為日常交接與權限盤點可以使用的依據。

[1] ISO 官方ISO/IEC 27001介紹

[2] Ragic 自動同步與需觸發的功能

參考查閱 2026/09/09